PENETRATION TESTING REPORT

FOOTPRINTING & NETWORK SCANNING PHASES

WEEK2 FINAL/CYBERSECURITY/ NETWORKWALKS

. Pentester Name (Cybersecurity professional)	Sanusi Najibat
Program Batch	BO84H Networkwalks
Modules Completed	WK 2: PM1 (Multiple Kali tools) WK 2 : PM2 (GHDB Dork) WK 2 : PM4 (theHarvester) WK 2 : PM5 (Zenmap Scanning)
Clients/Target	1. Networkwalks (secured written permission already) 2. My own local LAN Network
Permission secured already	Yes
Phases Covered	1. Reconnaissance and footprinting 2. Scanning 3. Phase 3-5 in progress

LIABILITY DISCLAIMER

I have performed these activities only on the device/system that I own myself. All these materials are for education and research purpose only. Do not use anything from here to break the law. The instructor, the authors and Networkwalks are not responsible for what you do with this knowledge. Every action you take is your own responsibility. Misuse can lead to criminal charges, heavy fines, loss of your job and a permanent record. In most countries unauthorised access is a crime even when nothing is damaged.

INTRODUCTION

This report covers footprinting the networkwalks.com domain using multiple Kali Linux tools (W2-PM1), GHDP (W2-PM2), theHarvester (W2-PM4) and scanning my own local network with Zenmap (W2-PM5). The first three modules covers the footprinting phase and the other covers the scanning phase, so together they show how an attacker moves from gathering public information to mapping live hosts on a network. It is the Week 2 part of my ongoing internship program at Networkwalks.
All commands were run in Kali Linux (footprinting) and on a Windows PC with Zenmap installed (scanning). Every step below includes the exact command used, the result I observed, a screenshot as evidence, and a short note on why the finding matters from an attacker's point of view.

TOOLS USED

The table below lists each tool used in this report and its purpose.

Tool	Purpose
Kali Linux & Windows	Operating systems used for reconnaissance activities
WHOIS	Find domain registration details (owner, dates, name servers).
whatweb	Fingerprint web technologies (server, CMS, plugins, IP).
nslookup	Resolve the domain name to its IP address using DNS.
curl -I	Read the HTTP response headers of the website.
wafw00f	Detect whether a Web Application Firewall protects the site.
dnsrecon	Enumerate all DNS records (NS, MX, SPF, TXT, SRV).
GHDB Dork	Find public accessible cam and PDF.
theHarvester	Find email IDs and subdomains related to a target organization.
Zenmap (Nmap GUI)	Scan the local subnet to find live hosts, IPs and MAC addresses.
Windows CMD	Local IP and MAC address identification

ACTIVITIES PERFORMED

Footprinting & Reconnaissance

I performed reconnaissance against the `networkwalks.com` domain using six Kali Linux tools: **WHOIS, WhatWeb, Nslookup, Curl, Wafw00f and DNSRecon**. Each tool was used to collect a different type of information about the target.

First, I used **WHOIS** to obtain publicly available domain registration information and identify the domain's name servers. The results provided information about the domain registration and hosting infrastructure.

I then used **WhatWeb** to identify technologies used by the website. The results identified **WordPress 7.0.4** and **WP Download Manager 3.3.58**, along with other information exposed by the website.

Using **Nslookup**, I resolved the domain name to its IP address. The provided result identified **192.232.216.135**.

I used **Curl** with the `-I` option to inspect the HTTP response headers. This provided additional information about the web application and exposed the WordPress REST API endpoint `/wp-json/`.

Next, I used **Wafw00f** to determine whether a Web Application Firewall was protecting the website. The result identified **ModSecurity (SpiderLabs)**.

I used **DNSRecon** to enumerate DNS records. The results provided information relating to name servers, mail servers, SPF/TXT records, service records and DNS software information.

I used the Google Hacking Database (GHDB) to perform passive reconnaissance on the target domain. Google dorks were used to identify publicly indexed PDF documents and exposed IP camera-related pages. This helped reveal potentially exposed resources and information that could pose security risks if not properly secured.

Finally I used theHarvester during the footprinting phase to gather publicly available information about the target organizations (Microsoft.com). The tool was used to identify email addresses and subdomains associated with the target organizations. I also used different search engines, including Baidu, to discover additional information that could help identify the organization's online presence and potential attack surfaces. Though No **IP** found and **Three emails** found using Baidu.

Network Scanning with Zenmap

For the second activity, I used **Zenmap** to perform network discovery on my local network. The practical required me to identify my local IP address and subnet, discover live hosts, identify their IP and MAC addresses, and generate a network topology.

I first used the Windows `ipconfig` command to identify my local IP address and LAN subnet. I then entered the subnet into Zenmap and selected **Ping Scan** to identify active hosts.

The example results provided in the practical identified four live hosts:

- `192.168.0.1`
- `192.168.0.101`
- `192.168.0.102`
- `192.168.0.104`
- `192.168.0.100`

The example results also included four MAC addresses.

After completing the scan, I opened the **Topology** section in Zenmap, enabled the legend and saved the network topology in PDF format as required by the practical task.

RISK ANALYSIS /IMPACT

Based on the information collected during the footprinting and network scanning activities, I identified the following potential risks.

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
1	Web technology information exposed	WhatWeb identified WordPress and WP Download Manager	Attackers may use exposed technology/version information to identify software requiring further security review	🟠 **Medium**
2	Server IP address identifiable	Nslookup resolved the domain to `192.232.216.135`	Provides information about the network location of the web service	🟡 **Low**
3	HTTP technical information exposed	Curl returned HTTP response headers and exposed `/wp-json/`	May assist technology fingerprinting and further enumeration	🟡 **Low**
4	WAF technology identifiable	Wafw00f identified ModSecurity (SpiderLabs)	Reveals information about the web application's security architecture	🟡 **Low**
5	DNS infrastructure information exposed	DNSRecon identified DNS, mail and service-related records	DNS information can help build a broader infrastructure profile	🟠 **Medium**
6	Multiple live hosts visible on local network	Zenmap identified four live hosts in the example network	Unknown or unauthorized devices may potentially be present on a network	🟠 **Medium**

Risk level key: 🔴 Critical 🟠 Medium 🟡 Low

The risks above are observations from the footprinting and scanning exercises, not confirmed vulnerabilities.

The practical exercises primarily involved information gathering and host discovery. No exploitation or vulnerability validation was performed as part of these two modules.

Therefore, the presence of information such as a software version, IP address or DNS record does not by itself mean that the system is vulnerable. Further authorized security testing would be required to confirm any actual vulnerability.

RECOMMENDATIONS

Based on the observations from these activities, I recommend the following security improvements:

1. **Review publicly exposed technology information**
   Organizations should regularly review what information about their web technologies, CMS and plugins is publicly visible.
2. **Keep software updated**
   CMS platforms, plugins and other web technologies should be regularly updated and reviewed against current security advisories.
3. **Review HTTP headers**
   HTTP response headers should be reviewed to determine whether unnecessary technical information is being exposed.
4. **Review DNS records regularly**
   DNS records should be checked periodically to ensure that only required information and services are publicly exposed.
5. **Properly configure and monitor the WAF**
   Keep the WAF (ModSecurity) enabled and tuned, since it already blocks naive attacks.
6. **Perform regular internal network discovery**
   Organizations should periodically scan their own networks to identify active devices.
7. **Investigate unknown devices**
   Any unexpected device discovered during network scanning should be investigated and verified.
8. **Maintain network documentation**
   Network topology and device information should be documented and updated regularly.
9. **Perform security testing with authorization**
   Reconnaissance and scanning should only be performed against systems and networks where appropriate authorization has been provided.

CONCLUSION

During Week 2 of my Cybersecurity & Ethical Hacking internship, I completed practical activities covering footprinting, reconnaissance and network scanning.

In the footprinting activity, I used six Kali Linux tools to collect information about the target domain. I learned how WHOIS can provide domain information, WhatWeb can identify web technologies, Nslookup can resolve domain names, Curl can inspect HTTP headers, Wafw00f can identify a WAF, and DNSRecon can provide additional DNS information. I also used GHDB

dork to identify publicly exposed information like cam and PDF. Finally I used theHarvester to check for email IDs and subdomain of a target organization (Microsoft.com).

In the network scanning activity, I used Zenmap to identify my local network configuration and discover active hosts. I also collected IP and MAC address information and created a network topology.

The exercises showed me that information gathering is an important part of cybersecurity. Even before attempting to exploit a system, a security professional can learn a significant amount about an environment by carefully analyzing publicly available information and network responses.

I also learned that technical findings should be documented clearly. A good cybersecurity report should explain what was performed, what was discovered, what the observation means, what risk it may create, and what can be done to reduce that risk.

Finally, I learned that reconnaissance and scanning must always be performed within an authorized scope. These activities were completed as part of the assigned educational cybersecurity lab.

EVIDENCE COLLECTED